Plan de Seguridad, Recuperación (RPO/RTO), Costos y Responsabilidades (`saasCloudDb` — Caso 8)

Este documento detalla la seguridad *Zero-Trust* de **`saasCloudDb`**, los procedimientos de respaldo y recuperación ante desastres (DRP), la matriz de responsabilidades por perfil técnico y la estimación de costos en nube.

---

1. Arquitectura de Seguridad y Protección de Datos Multi-Tenant

1.1 Autenticación y Autorización (Mínimo Privilegio en camelCase)

- **Autenticación Externa:** OIDC / OAuth 2.0 (JWT firmados con RS256) con MFA obligatorio para `OWNER` y `ADMIN`. El token incluye el claim inmutable `tenantId`.
- **Roles de Base de Datos (`sql/TenantSecurityRls.sql`):**
- `saasAppRuntime` (`NOBYPASSRLS`): Rol de aplicación en tiempo de ejecución. Solo tiene permisos `SELECT, INSERT, UPDATE, DELETE` sobre `tenantUsers`, `projects`, `workOrders`, `invoices` y `SELECT, INSERT` (append-only) sobre `auditEvents`.
- `saasProvisionerAdmin`: Usado exclusivamente por el Control Plane para `provisionTenant` y migraciones de esquema.
- `saasReadonlyAuditor`: Rol de solo lectura restringido por RLS.
- **Aislamiento Row-Level Security (RLS Forzado):**
- Todas las tablas tienen `ENABLE ROW LEVEL SECURITY` y `FORCE ROW LEVEL SECURITY`.
- La política `USING ("tenantId" = "currentAppTenantId"())` opera en modo **Fail-Closed**: si la sesión no fija `SET LOCAL app.currentTenantId = '<uuid>'`, devuelve `0 filas`.

1.2 Cifrado en Tránsito y en Reposo

Capa	Mecanismo Técnico	Configuración
Cliente -> Ingress	HTTPS / TLS 1.3	Certificados gestionados por AWS ACM con HSTS
App -> pgBouncerPooler -> saasCloudDb	mTLS / TLS 1.3 (`sslmode=verify-full`)	Certificados rotados cada 90 días
Volúmenes Persistentes (`pgDataPvc`)	Cifrado de bloque EBS `gp3` + KMS	**AES-256** (`saasDataEncryptionKey` en `MainInfrastructure.tf`)
Respaldos y Archivos WAL (`saasBackupsPitr`)	Server-Side Encryption `aws:kms`	**AES-256** con rotación automática anual

---

2. Plan de Respaldo, Recuperación y Objetivos RPO / RTO

Escenario de Fallo	Mecanismo de Recuperación	RPO	RTO	Evidencia en el Prototipo
Caída de un Pod `saasTenantApi`	Kubernetes `Deployment` + `readinessProbe`	**0 s**	**< 2 s**	**`SaasApiAndAutoscaler.yaml`**
Caída de un Nodo de BD (`nodeAz1Pool`) o Pérdida de una AZ	Promoción automática de Réplica Síncrona en `nodeAz2Pool` (`simulateNodeFailover`)	**0 s**	**Prod: < 30 s** **Prototipo: 176,17 ms**	`TEST 07` en **`TestReport.json`**
Corrupción Lógica o Borrado Accidental	Restauración Point-in-Time Recovery (`restoreClusterBackup`)	**Prod: <= 60 s** **Snapshot: 0 s**	**Prod: <= 15 min** **Prototipo: 27,03 ms**	`TEST 08` con verificación SHA-256

---

3. Plan de Implementación y Responsabilidades por Perfil (Sección J)

Perfil / Rol	Responsabilidades Técnicas	Archivos Asociados
1. Arquitecto de Datos	Diseño del modelo híbrido Relacional+JSONB en `saasCloudDb` , claves compuestas `("tenantId", "orderId")` , co-localización y aislamiento Pool + Silo.	**`DataModel.sql`** , **`ShardingAndDistribution.sql`**
2. Ingeniero SRE / Cloud Native	Configuración de StatefulSets Multi-AZ, StorageClasses, PodDisruptionBudgets, HPA, Terraform y automatización de Failover y Backups.	**`kubernetes/`** , **`terraform/`** , **`docker-compose.yml`**
3. Ingeniero SecOps	Políticas Row-Level Security (`TenantSecurityRls.sql`), RBAC, NetworkPolicies Zero-Trust, cifrado KMS y auditoría inmutable (`auditEvents`).	**`TenantSecurityRls.sql`** , **`NetworkAndRbac.yaml`**
4. Ingeniero Backend & QA	Implementación de `ClusterEngine.py` , `SyntheticData.py` , idempotencia, concurrencia optimista (OCC), Token Bucket y `TestSuite.py` .	**`ClusterEngine.py`** , **`SyntheticData.py`** , **`TestSuite.py`**

---

4. Estimación de Costos Mensuales en Nube (5.000 Organizaciones) (Sección K)

Componente	Especificación (3 Zonas de Disponibilidad)	Cantidad	Costo Mensual (USD)
Control Plane EKS + ALB Multi-AZ	Clúster EKS + Balanceador Multi-AZ	1 Clúster	$145,00
Capa `saasTenantApi` + `pgBouncerPooler`	Instancias `c6i.xlarge` (4 vCPU, 8 GB RAM) en 3 AZs	6 Nodos	$620,00
`citusCoordinator` (HA)	Instancias `r6i.xlarge` (4 vCPU, 32 GB RAM) Primario + Standby	2 Nodos	$580,00
Workers Pool (`nodeAz1Pool` , `nodeAz2Pool`)	Instancias `r6i.2xlarge` (8 vCPU, 64 GB RAM) Primarios + Réplicas	4 Nodos	$2.320,00
Workers Silo (`nodeAz3Silo` Enterprise)	Instancias `r6i.2xlarge` dedicadas para los 150 clientes Enterprise	2 Nodos	$1.160,00
Almacenamiento SSD (`gp3`)	6 TB aprovisionados (12.000 IOPS, cifrado KMS)	6.000 GB	$540,00
`redisRateLimiter` Cluster	Nodos `cache.r6g.large` en 3 AZs	3 Nodos	$390,00
Respaldos S3 (`saasBackupsPitr`) + Tráfico Inter-AZ	4 TB en S3 + Replicación entre zonas	Global	$385,00
TOTAL MENSUAL INFRAESTRUCTURA	**~ $1,23 USD / organización / mes en promedio**	—	**$6.140,00 USD / mes**